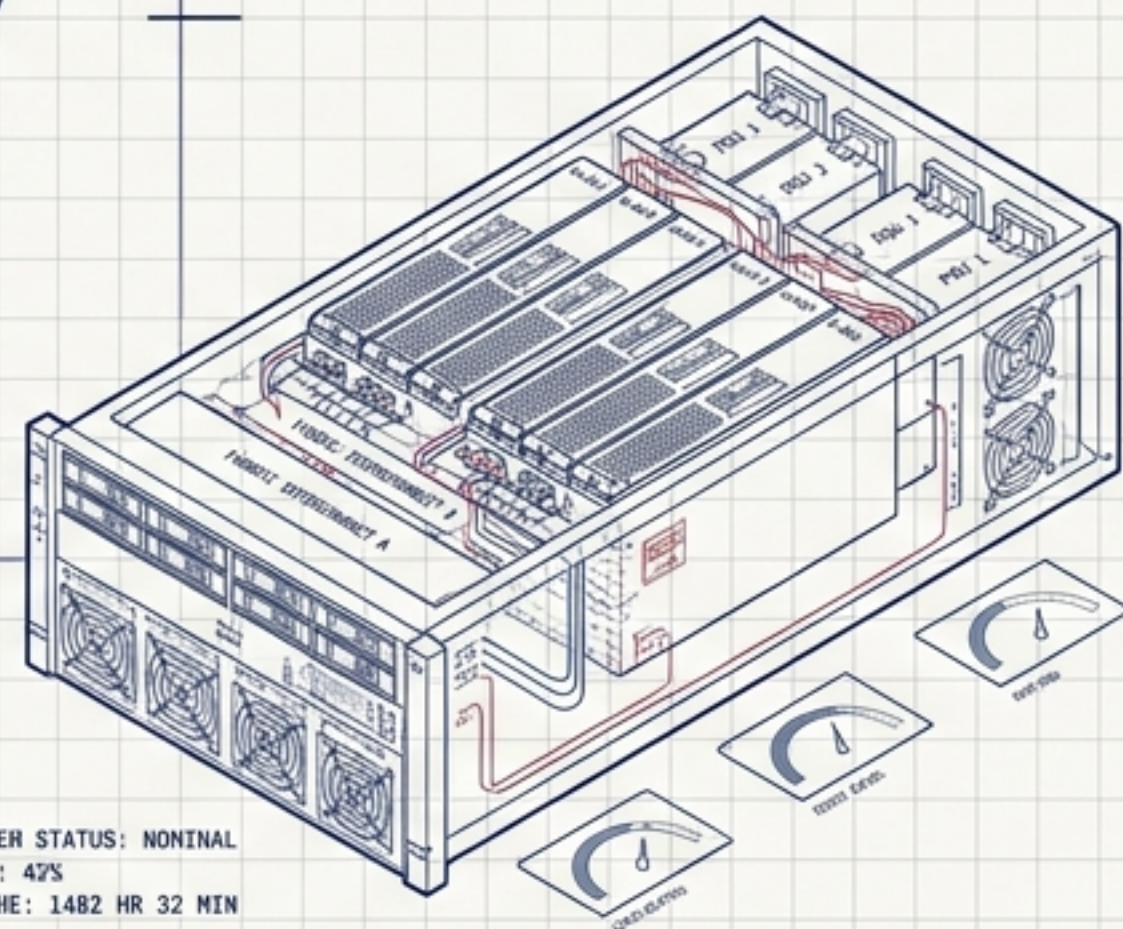


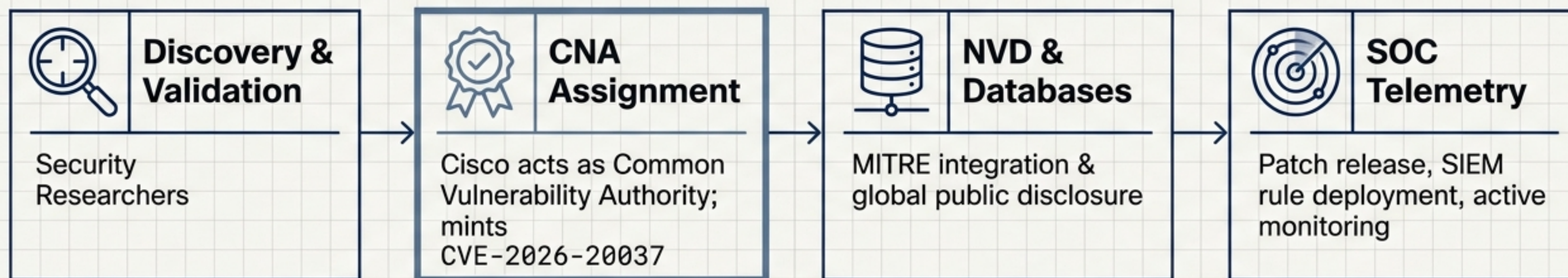
Security Analysis: CVE-2026-20037

Cisco UCS Manager File Write
Vulnerability & CWE-250 Deep Dive



SYSTEM STATUS: NORMAL
LOAD: 42%
UPTIME: 1482 HR 32 MIN

The Vulnerability Lifecycle Ecosystem



The pathway from raw discovery to tracked entity within the MITRE CVE ecosystem.

Threat Profile: CVE-2026-20037

Target Details	
Vendor:	Cisco
Product:	Cisco Unified Computing System (UCS Manager)
Attack Interface:	Cisco Unified Computing System (UCS Data Manager)
Attack Interface:	NX-OS CLI

Metrics



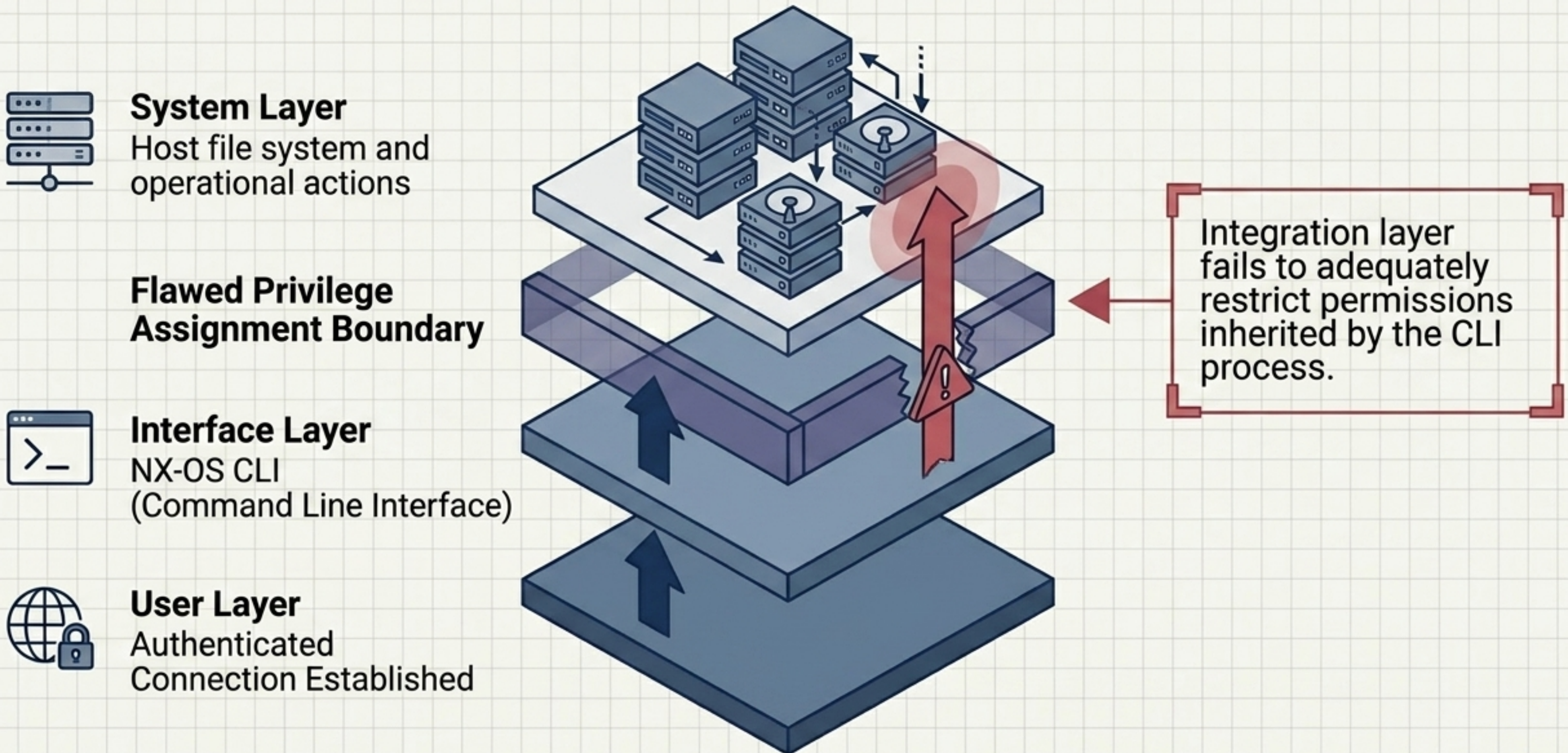
4.4

Medium Severity

Weakness Class: **CWE-250** (Execution with Unnecessary Privileges)

Attack Vector: Local Authenticated Access

Cisco UCS Manager & NX-OS CLI Integration



Root Cause Analysis: CWE-250

Execution with Unnecessary Privileges

Expected Behavior (Least Privilege)

Role:

Read-Only User

Capabilities:

- ✓ View configurations
- ✓ Monitor system status

System State: Secure, strictly partitioned.



Actual Behavior (CWE-250 Exploitation)

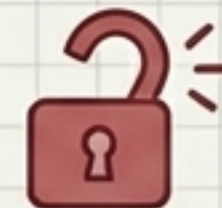
Role:

Read-Only User (Elevated via NX-OS)

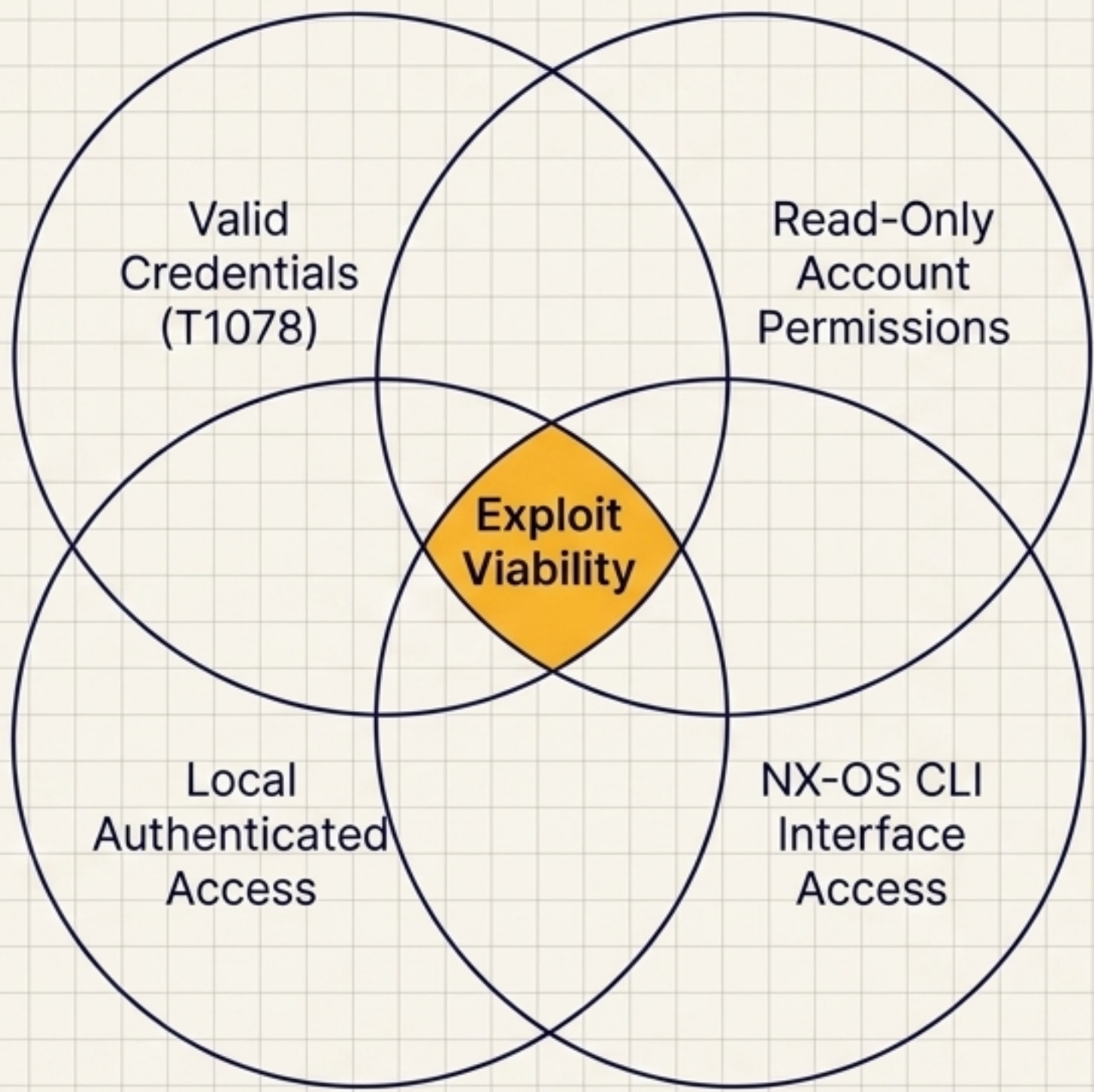
Capabilities:

- ⚠ Create files
- ⚠ Overwrite files
- ⚠ Perform privileged actions

System State: Compromised, excessive permission leak.

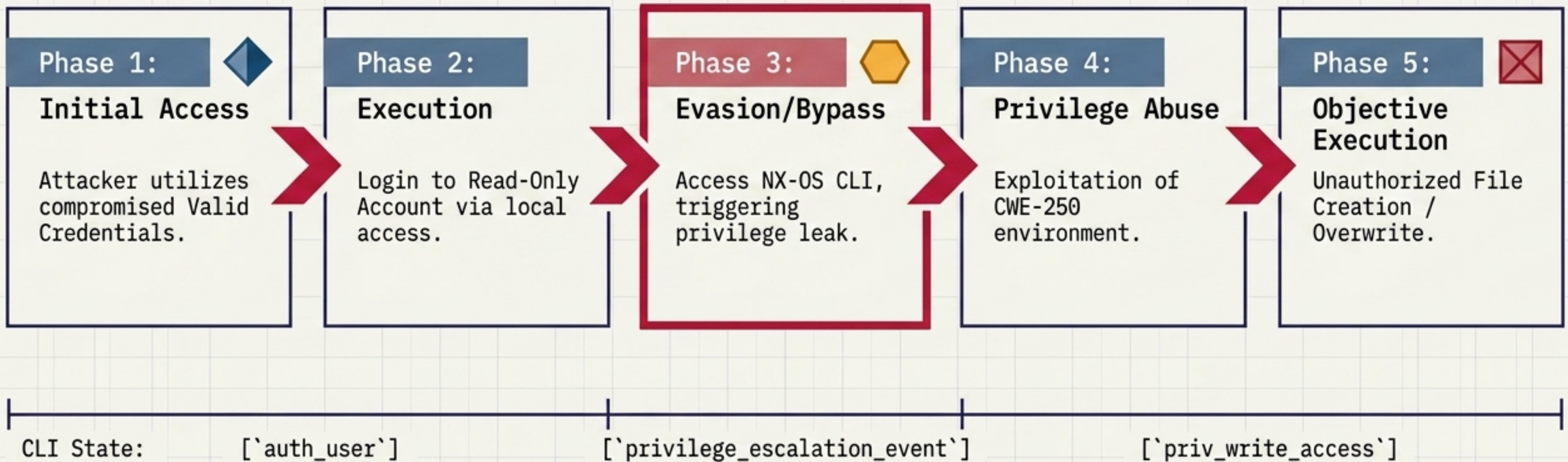


Exploitation Preconditions



Excluded Factors
Administrator Access (Not Required)
Remote Unauthenticated Exploitation (Not Possible)
User Interaction (Not Required)

Technical Exploitation Kill Chain



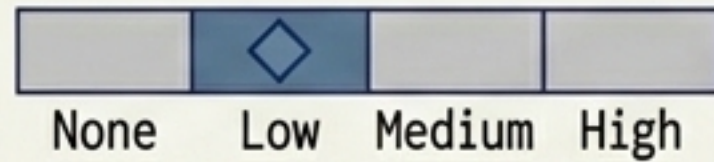
CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N

CVSS v3.1 Vector Breakdown

Attack Vector (AV)

Local

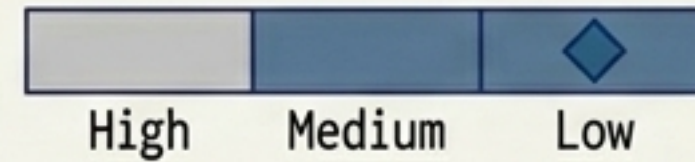
(Constrains threat heavily)



Attack Complexity (AC)

Low

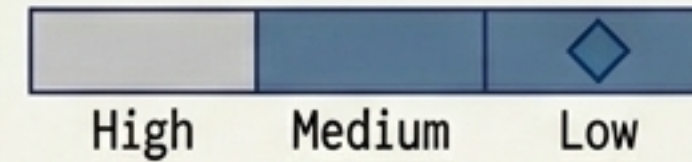
(Reliable once preconditions met)



Privileges Required (PR)

Low

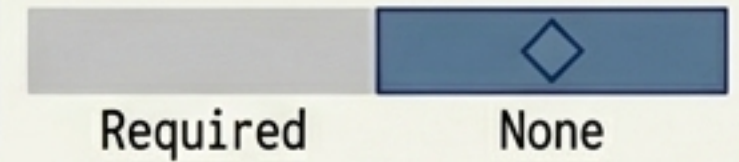
(Read-only suffices)



User Interaction (UI)

None

(Not Required)



Scope (S)

Unchanged

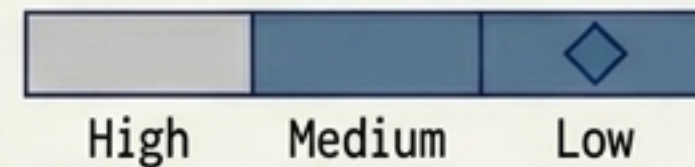
(Vulnerability limited to component)



Confidentiality (C)

Low

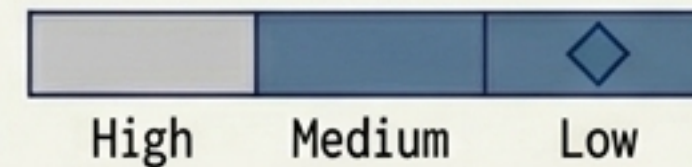
(Limited information disclosure)



Integrity (I)

Low

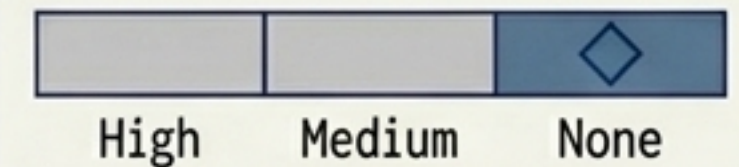
(Minor data modification)



Availability (A)

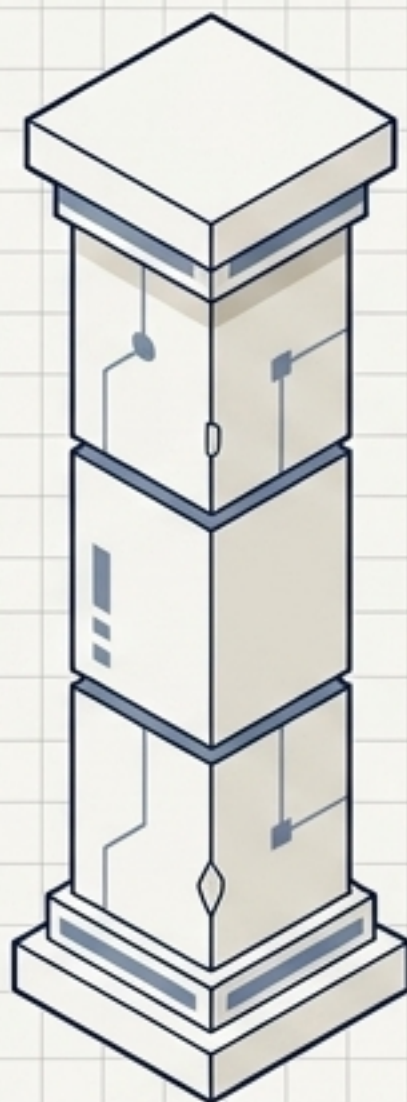
None

(No impact on availability)



Impact Assessment: CIA Triad

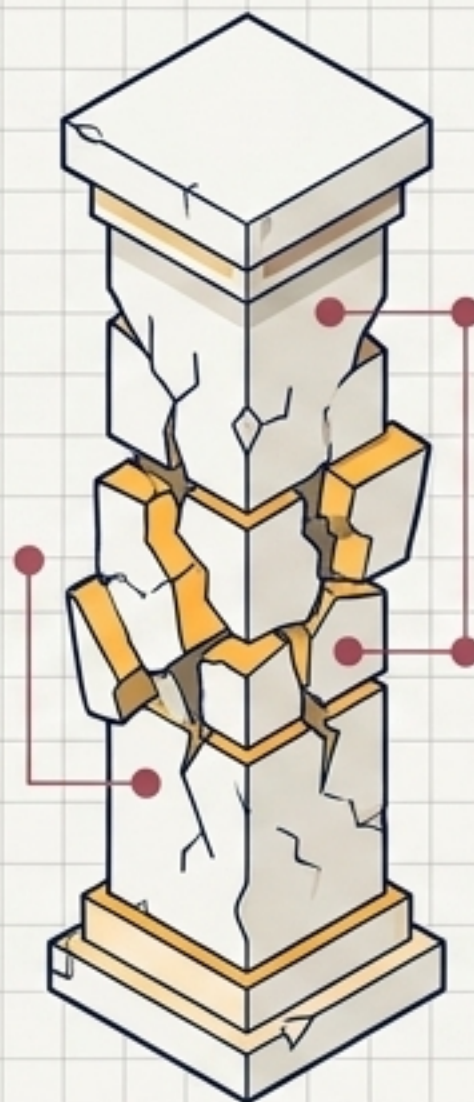
Confidentiality



Impact: Low

Limited to unauthorized information exposure via newly created/accessed files.

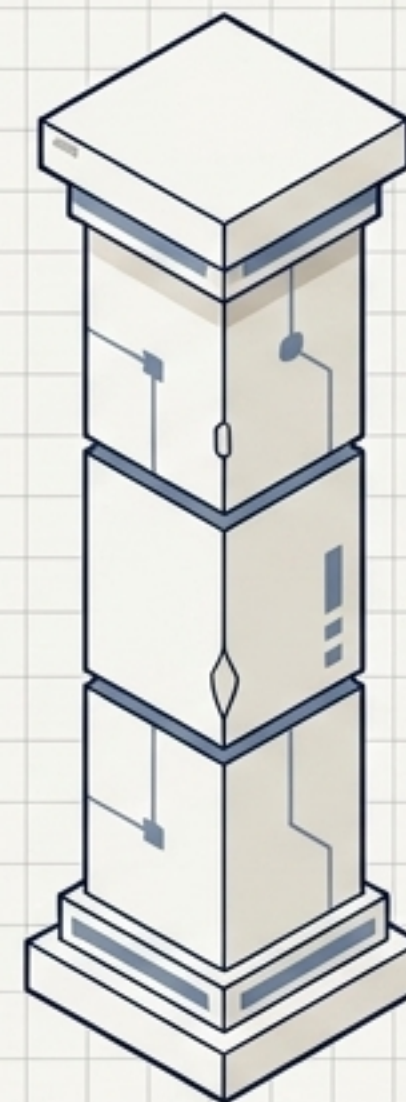
Integrity



Impact: Low/Medium

The core damage. Unauthorized file modification and overwrite capabilities.

Availability



Impact: None

No direct service disruption or denial of service occurs.

Business Risk

Unauthorized operational actions, hidden system changes, and direct violations of enterprise security and compliance policies.

Threat Intelligence: MITRE ATT&CK Mapping

T1078 - Valid Accounts

The necessary initial access vector.

T1548 - Abuse Elevation Control Mechanism

The core CWE-250 exploitation via NX-OS CLI.

T1222 - File Permission Modification

The resulting payload execution (file writes).

T1098 - Account Manipulation

Secondary impact through operational actions.

Detection Engineering & Telemetry

Indicators of Compromise (IOCs)



Unusual NX-OS CLI sessions originating from low-tier accounts.



Unexpected file creation in restricted directories.



Privileged commands executed by read-only users.

SIEM & Monitoring Rules



LOG_ANALYSIS

Authentication and CLI access logs.



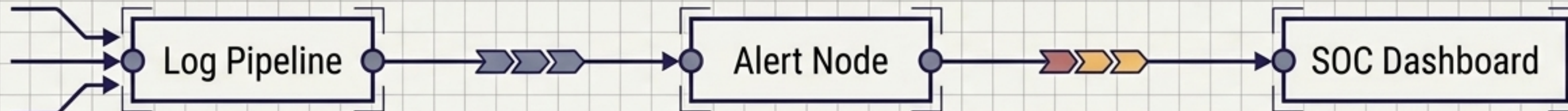
FIM_ALERT

File Integrity Monitoring on unauthorized overwrites.



CORRELATION

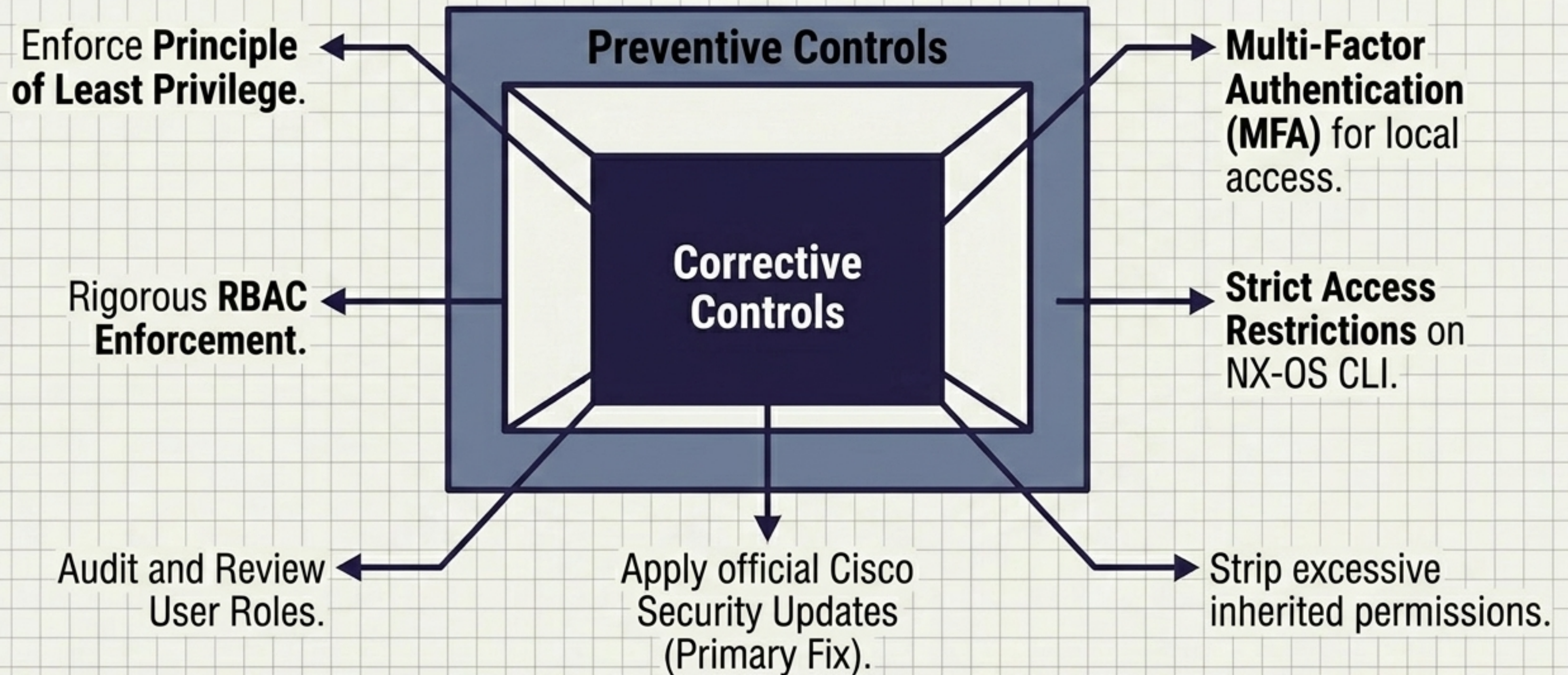
Cisco Security Advisory alerts mapped to local auth anomalies.



Continuous Assessment Workflow



Defense-in-Depth: Mitigation Strategy



The Future of Vulnerability Management

Current Imperatives

- Identify
 - Assess
 - Prioritize
 - Remediate
- Enable Logging & Monitor User Activity

Capability Evolution

Next-Generation Capabilities

- AI-driven Detection and anomaly hunting.
- ◆ Automated Risk Scoring (Contextualizing CVSS dynamically).
- ◇ Continuous Security Validation.
- ▣ Predictive Vulnerability Analysis.

Key Findings & Reference Library

Key Findings

- ◆ CVE-2026-20037 exposes a critical systemic design flaw (CWE-250) despite its 4.4 Medium score.
- ◆ Unauthorized file modification via NX-OS CLI shatters the expected boundaries of read-only accounts.
- ◆ **The vulnerability underscores the absolute necessity of strict RBAC and continuous privilege auditing.**
- ◆ Mitigation requires immediate patching combined with behavioral SIEM monitoring.

Reference Library

- [1] Cisco Security Advisory (CVE-2026-20037)
- [2] MITRE CVE & ATT&CK Frameworks
- [3] NIST National Vulnerability Database (NVD)
- [4] CWE-250: Execution with Unnecessary Privileges